

# Table of Contents

- 1. [Overview](#)
  - [Scope](#)
- 2. [Executive Summary](#)
  - [Mystic Panel](#)
- 3. [Technical Analysis](#)
  - [String and Code Obfuscation](#)
  - [Hierarchical Working](#)
  - [Stealing Capabilities](#)
  - [Browser Hijacking](#)
  - [Cold Wallets](#)
  - [Checked Banking Domains](#)
  - [Command and Control Communication](#)
- 4. [Conclusion](#)
- 5. [YARA Rule](#)
- 6. [MITRE ATT&CK Threat Matrix](#)
- 7. [IOC Table](#)

---

## 1. Overview

### 1.1 Scope

| File Name | stealer.exe                                                        |
|-----------|--------------------------------------------------------------------|
| md5       | bdc486117f48fef2b268ad2de305ef3d                                   |
| sha1      | 52f907d6325e3c5ccb72baf7589d1dbe81f5df80                           |
| sha256    | b37ab91f8163344b775edc9a4378d44fdfd dbac3b0cd3fcea f670f79b06bc362 |

---

## 2. Executive Summary

The evolving landscape of cyber threats continues to present significant challenges for individuals and organizations worldwide. In recent years, a new strain of malware, known as Mystic Stealer, has emerged as a prominent threat in the digital realm. This report aims to provide an in-depth analysis of Mystic Stealer, a stealer malware that first surfaced in April 2023. Its builder and panel are being actively traded in underground forums, following a Malware-as-a-Service (MaaS) model.

Mystic Stealer represents a basic yet potent stealer malware that specifically targets browser information, system specifics, screenshots, and various browser extension wallets, including cold crypto wallets. Stealing capabilities of Mystic Stealer include:

- **Browser Hijacking:** Passwords, History, Credit Cards, Sessions, Cookies, Autofill.
- **Extensions:** Crypto wallets, Password managers, Multi-factor authenticators.
- **Cold wallets**
- **System information**
- **Screenshot**

## 2.1 Mystic Panel

Panel images in this section are taken from the public Telegram sales channel of Mystic Stealer malware. Although Mystic Stealer itself is written in C, the panel is written in the Python programming language alongside Bootstrapper and Django frameworks. At the time, the malware panel's default SSH (22) and HTTP (80) ports are open. Current infrastructure runs on the Ubuntu operating system and nginx web server with version 1.18.0. Based on these parameters, other addresses that host the Mystic Stealer Panel are provided in the IOC section.

The malware builder is integrated into the malware panel which can be configured to add anti-virtualization and anti-reverse engineering techniques.

*Figure 1: Log panel*

Settings page enables panel users to configure the malware and prefer information type which they want to be stolen.

*Figure 2: Panel filter configuration to view stolen information*

Panel users can change the built malware file format into `.exe` or `.dll`. It also allows users to add more than one command and control server address.

*Figure 3: Malware builder in panel*

---

## 3. Technical Analysis

This section contains technical analysis of the Mystic stealer sample provided in the Scope section.

### 3.1 String and Code Obfuscation

Analyzed mystic stealer sample involves string obfuscation. Strings are either XOR or character encoded.

*Figure 4: String obfuscation*

Analyzed Mystic stealer doesn't include an IAT table since all the API calls are made by a custom implemented API wrapper. The return of the API call wrapper is passed to the EAX register, then it is called. Also, it loads the `ntdll` library itself. This way, malware evades static analysis engines of various sandboxes and escapes from software breakpoints on API functions.

*Figure 5: API wrapper*

### 3.2 Hierarchical Working

At first stages of main function execution, the command and control server IP is decoded. The most important part in the analysis is the command and control server connection check malware performs. If TCP communication with the IP cannot be established, the sample stops execution.

*Figure 6: C2 decoding and communication check*

*Figure 7: Main function*

[!NOTE] **Analyst Note:** Although this sample doesn't have any anti-virtualization or anti-debug countermeasures, the builder allows customers to add these functionalities. Therefore, samples may not reveal some of the features which are based on the malware build configuration.

Before making the first connection to the command and control server, malware creates a machine identifier based on the following registry value: `SOFTWARE\Microsoft\Cryptography\MachineGuid`

*Figure 8: Creation of machine identifier*

[!NOTE] **Analyst Note:** To be noted, functions in the image are renamed during analysis to provide insight about capabilities of the functions, names are not available in the sample itself.

After creating the machine identifier, malware collects system specifics. The following information is collected from the system:

- Username
- Computer name
- Display devices
- CPU model
- Number of processors
- System metrics
- Windows product name
- Sample file name
- System language
- Available memory space
- Keyboard layout list
- System locale

*Figure 9: Gathered system specifications*

## 3.3 Stealing Capabilities

### 3.3.1 Browser Hijacking

Mystic stealer can steal browser logins, cookies, saved credit cards, history, and information stored by extensions.

Figure 10: Stolen browser information

Decoded identifiers of targeted browser extensions are provided in the debugger memory dump.

Figure 11: Checked browser extensions

Targeted cryptocurrency wallets and 2FA extensions include:

- **TronLink** (ibnejdfjmmkpcnlpebklmnkoeoihofec)
- **BinanceChain** (fhbohimaelbohpbjbb1dcngcnapndodjp)
- **Yoroi** (ffnbelldoeiohenkjibnmadjiehjhajb)
- **Nifty Wallet** (jbdaocneiininmjbjlga lhcelgbejmnid)
- **Math Wallet** (afbcbjpbpfad lkmhmc lhkeeodmamcflc)
- **Coinbase Wallet** (hnfanknocfeofbddgcijnmhnfnkdnaad)
- **Guarda** (hpgIfhgfnhbgpjdenjgmdgoeiappafin)
- **EQUAL Wallet** (blnieiiffboillknjnepogjhkgnoapac)
- **Jaxx Liberty** (cjelfplplebdjjenllpjcb lmkjfcffne)
- **BitApp Wallet** (fihkakfobkmkjojpchpfgcmhfjnmnfpi)
- **iWallet** (kncchdigobghenbbaddojjnaogfppfj)
- **Wombat** (amkmjmmflddogmhpjloimipbofnfjih)
- **MEW CX** (nlbmnnijcnlegkjjpcfjclmcfggfefdm)
- **Guild Wallet** (nanjmdknhkinifnkgdcggcfnhdaammj)
- **Saturn Wallet** (nkddgncdjgjfcdamfgcmfnlhccnimig)
- **Ronin Wallet** (fnjhmkhhmkbjkkabndcnnogagogbneec)
- **NeoLine** (cphhlmgameodnhkjdmkpanlelnlohao)
- **Clover Wallet** (nhnkbkgjikgcigadomkphalanndcapjk)
- **Liquidity Wallet** (kpfopek lmapcoipemfendmdcghnegimn)
- **Terra Station** (aiifbnbfobpmeekipheeijimdpnlpgpp)
- **Keplr** (dmkamcknogkgcdfhhbdcghachkejeap)
- **Sollet** (fhmfendgdocmbmfikdcogofphimnkno)
- **Auro Wallet** (cnmamaachppnkjgnildpdmkaakejnhae)

- **Polymesh Wallet** (j~~o~~j~~h~~f~~e~~o~~e~~d~~k~~p~~k~~g~~l~~b~~f~~i~~m~~d~~f~~a~~b~~p~~d~~f~~j~~a~~o~~o~~l~~a~~f~~)
- **ICONex** (f~~l~~p~~i~~c~~i~~i~~e~~l~~e~~m~~g~~h~~b~~m~~f~~a~~l~~i~~c~~a~~j~~o~~o~~l~~h~~k~~k~~e~~n~~f~~e~~l)
- **Nabox Wallet** (n~~k~~n~~h~~i~~e~~h~~l~~k~~l~~i~~p~~p~~a~~f~~a~~k~~a~~e~~k~~l~~b~~e~~g~~l~~e~~c~~i~~f~~h~~a~~d~~)
- **KHC** (h~~c~~f~~l~~p~~i~~n~~c~~p~~p~~p~~d~~c~~l~~i~~n~~e~~a~~l~~m~~a~~n~~d~~i~~j~~c~~m~~n~~k~~b~~g~~n~~)
- **Temple** (o~~o~~k~~j~~l~~b~~k~~i~~i~~j~~i~~n~~h~~p~~m~~n~~j~~f~~f~~c~~o~~f~~j~~o~~n~~b~~f~~b~~g~~a~~o~~c~~)
- **TezBox** (m~~n~~f~~i~~f~~e~~f~~k~~a~~j~~g~~o~~f~~k~~c~~j~~k~~e~~m~~i~~d~~i~~a~~e~~c~~o~~c~~n~~k~~j~~e~~h~~)
- **DAppPlay** (l~~o~~d~~c~~c~~j~~j~~b~~d~~h~~f~~a~~k~~a~~e~~k~~d~~i~~a~~h~~m~~e~~d~~f~~b~~i~~e~~l~~d~~g~~i~~k~~)
- **BitClip** (I~~j~~m~~p~~g~~k~~j~~f~~k~~b~~f~~h~~o~~e~~b~~g~~o~~g~~f~~l~~f~~e~~b~~n~~m~~e~~j~~m~~f~~b~~m~~l~~)
- **Steem Keychain** (I~~k~~c~~j~~l~~n~~j~~f~~p~~b~~i~~k~~m~~c~~m~~b~~a~~c~~h~~j~~p~~d~~b~~i~~j~~e~~j~~f~~l~~p~~c~~m~~)
- **MetaMask** (n~~k~~b~~i~~h~~f~~b~~e~~o~~g~~a~~e~~a~~o~~e~~h~~l~~e~~f~~n~~k~~o~~d~~b~~e~~f~~g~~p~~g~~k~~n~~n~~)
- **Hycon Lite Client** (b~~c~~o~~p~~g~~c~~h~~h~~o~~j~~m~~g~~g~~m~~f~~i~~l~~p~~l~~m~~b~~d~~i~~c~~g~~a~~i~~h~~l~~k~~p)
- **ZilPay** (k~~l~~n~~a~~e~~j~~j~~g~~b~~i~~b~~m~~h~~l~~e~~p~~h~~n~~h~~p~~m~~a~~o~~f~~o~~h~~g~~k~~p~~g~~k~~d~~)
- **Coin98 Wallet** (a~~e~~a~~c~~h~~k~~n~~m~~e~~f~~p~~h~~e~~p~~c~~c~~i~~o~~n~~b~~o~~o~~h~~c~~k~~o~~n~~o~~e~~e~~m~~g~~)
- **Authenticator** (b~~h~~g~~h~~o~~a~~m~~a~~p~~c~~d~~p~~b~~o~~h~~p~~h~~i~~g~~o~~o~~o~~a~~d~~d~~i~~n~~p~~k~~b~~a~~i~~)
- **Cyano Wallet** (d~~k~~d~~e~~d~~l~~p~~g~~d~~m~~m~~k~~k~~f~~j~~a~~b~~f~~f~~e~~g~~a~~n~~i~~e~~a~~m~~f~~k~~l~~k~~m~~)
- **Byone** (n~~l~~g~~b~~h~~d~~f~~g~~d~~h~~g~~b~~i~~a~~m~~f~~d~~f~~m~~b~~i~~k~~d~~g~~h~~i~~d~~o~~a~~d~~d)
- **Nash Extension** (o~~n~~o~~f~~p~~n~~b~~b~~k~~e~~h~~p~~m~~m~~o~~a~~b~~g~~p~~c~~p~~m~~i~~g~~a~~f~~m~~m~~n~~j~~h~~l~~)
- **Leaf Wallet** (c~~i~~h~~m~~o~~a~~d~~a~~i~~g~~h~~c~~e~~j~~o~~p~~a~~m~~m~~f~~b~~m~~d~~d~~c~~m~~d~~e~~k~~c~~j~~e~~)
- **Authy 2FA** (g~~a~~e~~d~~m~~j~~d~~f~~m~~m~~a~~h~~h~~b~~j~~e~~f~~c~~b~~g~~a~~o~~l~~h~~h~~a~~n~~l~~a~~o~~l~~b~~)
- **EOS Authenticator** (o~~e~~l~~j~~d~~l~~d~~p~~n~~m~~d~~b~~c~~h~~o~~n~~i~~e~~l~~i~~d~~g~~o~~b~~d~~d~~f~~f~~f~~l~~a~~l~~)
- **GAuth Authenticator** (i~~l~~g~~c~~n~~h~~e~~l~~p~~c~~h~~n~~c~~e~~e~~i~~p~~i~~p~~i~~j~~a~~l~~j~~k~~b~~l~~b~~c~~o~~b~~l~~)
- **Trezor Password Manager** (i~~m~~l~~o~~i~~f~~k~~g~~j~~a~~g~~g~~h~~n~~n~~c~~j~~k~~h~~g~~g~~d~~h~~a~~l~~m~~c~~n~~f~~k~~l~~k~~)
- **OneKey** (i~~n~~f~~e~~b~~o~~a~~j~~g~~f~~h~~g~~b~~j~~p~~j~~b~~e~~p~~p~~b~~k~~g~~n~~a~~b~~f~~d~~k~~d~~a~~f~~)
- **EVER Wallet** (c~~g~~e~~e~~o~~d~~p~~f~~a~~g~~j~~c~~e~~e~~f~~i~~e~~f~~l~~m~~d~~f~~p~~h~~l~~k~~e~~n~~i~~f~~k)
- **KardiaChain Wallet** (p~~d~~a~~d~~j~~k~~f~~k~~g~~c~~a~~f~~g~~b~~c~~e~~i~~m~~c~~p~~b~~k~~a~~l~~n~~f~~n~~e~~p~~b~~n~~k~~)
- **Rabby Wallet** (a~~c~~m~~a~~c~~o~~d~~k~~j~~b~~d~~g~~m~~o~~l~~e~~e~~b~~o~~l~~m~~d~~j~~o~~n~~i~~l~~k~~d~~b~~c~~h~~)
- **Phantom** (b~~f~~n~~a~~e~~l~~m~~o~~m~~e~~i~~m~~h~~l~~p~~m~~g~~j~~n~~j~~o~~p~~h~~p~~k~~k~~o~~l~~j~~p~~a)
- **Oxygen – Atomic Crypto Wallet** (f~~h~~i~~l~~a~~h~~e~~i~~m~~g~~l~~i~~g~~n~~d~~d~~k~~j~~g~~o~~f~~k~~c~~b~~g~~e~~k~~h~~e~~n~~b~~h~~)

- **Pali Wallet** (mgffkfbiidihjpoaomajlbgchddlicgpn)
- **XDEFI Wallet** (hmeobnfnfcmkdcmlblgagmfpfboieaf)
- **Nami** (Ipfcbjknijeeillifnkikgncikgfhdo)
- **MultiversX DeFi Wallet** (dngmlblcodfobpdpecaadgfbcggfjfnm)
- **Solflare Wallet** (bhhhlbepdkbapadjdnnojkbgioidbic)
- **Goby** (jnkel fanjkeadonecabehalmbgpfodjm)
- **SteemKeychain** (jhgnbkkipaallpehbohjmkbjofjdmeid)
- **Braavos Smart Wallet** (jnlgamecbpmbajjfhhmmlejkemejdma)
- **Enkrypt** (kkpllkodjeloidieedojogacfhpaihoh)
- **OKX Wallet** (mcohilncbfahbmgdjkbpemcciolgcge)
- **Hashpack** (gjagmgiddbbciopjhllkdnddhcglnemk)
- **Eternl** (kmhciehpebfmpgmihbkipmjlmioameka)
- **Pontem Aptos Wallet** (phkbamefinggmakgklpkljmgibohnba)
- **Keeper Wallet** (Ipilbniiabackdjcionkobglmddfbcjo)
- **Finnie** (cjmknjdjhnagcfbpiemnkdpomccnjbmlj)
- **Leap Terra Wallet** (aijcbedoijmgnlmjeegjaglmepbmkpi)
- **Dashlane Password Manager** (fdjamakpfbbddfjaoaikfcpapjohcfmg)
- **NordPass Password Manager** (fooolghllnmhmmndgjiamiodkpenpbb)
- **RoboForm Password Manager** (pnlccmojcmeohlpggmfnbbiapkmbliob)
- **LastPass** (hdokiejnpimakedhajhdIcegeplioahd)
- **Browserpass** (naepdomgkenhino locfifgehiddafch)
- **MYKI Password Manager & Authenticator** (bmikpgodpkclnkgmnpphehdgcimmided)
- **Martian Wallet for Sui & Aptos** (efbglgofoippbgcjepnhiblaibcnclogk)

Browser paths checked by Mystic Stealer include Google Chrome, Microsoft Edge, Chromium, Opera, Yandex, Brave, Vivaldi, and many derivative or niche browsers.

### 3.3.2 Cold Wallets

Targeted cold cryptocurrency wallets include:

- Monero
- Exodus

- Binance
- Raven
- atomic\_qt
- Armory
- Dogecoin
- MultiBit
- DashCore
- Electrum
- LiteCoin
- BitcoinGold
- Wasabi Wallet
- Guarda
- Electrum-LTC
- MyCrypto
- Bisq/btc\_mainnet
- DeFi blockchain
- Coinomi
- TokePocket
- com.liberty.jaxx

### 3.3.3 Checked Banking Domains

Various domains checked in browser logins include:

- `online.canarabank.in`
- `ms.portal.azure.com`
- `dev.azure.com`
- `outlook.office365.com`
- `tasks.office.com`
- `autofill.account.microsoft.com`
- `turbotax.intuit.com`

- [bankofamerica.com](https://bankofamerica.com)
- [secure.bankofamerica.com](https://secure.bankofamerica.com)

### 3.4 Command and Control Communication

Mystic Stealer sends the hexadecimal value `0x946F19B5` to initialize TCP server communication.

*Figure 13: Package prefix*

Mystic Stealer sends information after every enumeration function instead of creating a log file in the system. Since it communicates with the server while performing its checks, it creates a lot of noise in the network which makes its detection easier on the system.

*Figure 14: Network communication made by sample*

---

## 4. Conclusion

As the demand for stolen information grows within the cybercriminal ecosystem, the availability and accessibility of malicious tools like Mystic Stealer have reached unprecedented levels. The sale of the builder and panel in underground forums enables even non-technical individuals to deploy this malware for malicious purposes. Consequently, understanding the inner workings, capabilities, and potential impact of Mystic Stealer is paramount in developing effective defensive strategies and mitigating its risks.

---

## 5. YARA Rule

```
rule mystic_stealer_v1{
  meta:
    author = "@batcain_"
    source = "brandefense.io"
    date = "10.07.2023"
  strings:
    $hex4 = {FF B4 24 ?? OF 00 00 8B CA 8D 84 24 ?? 01 00 00 FF B4 24
    ?? OF 00 00 C1 E9 02 FF B4 24 ?? OF 00 00 F3 A5 FF B4 24 ?? OF 00 00 8B CA
    FF B4 24 ?? OF 00 00 83 E1 03 FF B4 24 ?? OF 00 00 F3 A4 55 50 53 53 FF B4
    24 ?? OF 00 00 E8 ???? 00 00}
  condition:
    all of them and filesize <300KB
}
```

---

## 6. MITRE ATT&CK Threat Matrix

### 1. TA0002 Execution

- T1204 User Execution



- **T1204.002 Malicious File**
  - 2. **TA0005 Defense Evasion**
    - **T1140 Deobfuscate/Decode Files or Information**
  - 3. **TA0006 Credential Access**
    - **T1555 Credentials from Password Stores**
    - **T1555.003 Credentials from Web Browsers**
    - **T1555.005 Password Managers**
    - **T1539 Steal Web Session Cookie**
  - 4. **TA0007 Discovery**
    - **T1082 System Information Discovery**
    - **T1033 System Owner/User Discovery**
  - 5. **TA0009 Collection**
    - **T1005 Data From Local System**
  - 6. **TA0011 Command and Control**
    - **T1573 Encrypted Channel**
    - **T1573.001 Symmetric Cryptography**
  - 7. **TA0010 Exfiltration**
    - **T1041 Exfiltration Over C2 Channel**
- 

## 7. IOC Table

### Sample C2

- `164.132.200.171`

### V1.2 Panels

- `lib.sultanolama.com`
- `byggmastarn.nu`
- `s3.my-servers.us`
- `byggmastarniskane.se`
- `marisolblooms.com`
- `45.9.74.110`

- 95.216.32.74
- 94.130.164.47

## V2 Panels

- 109.248.206.137
- 116.202.233.49
- 137.206.248.109
- 142.132.201.228
- 142.93.11.96
- 167.235.34.144
- 188.40.116.251
- 193.233.48.167
- 212.113.106.114
- 34.88.245.41
- 5.188.87.45
- 5.196.93.222
- 5.42.94.125
- 5.75.183.169
- 64.52.80.55
- 89.23.107.241
- 91.121.118.80
- 94.130.164.47
- 94.130.165.48
- 94.130.216.165
- 95.216.32.74

## Other Mystic Stealer Sample Hashes

- 47439044a81b96be0bb34e544da881a393a30f0272616f52f54405b4bf288c7c
- 39d3532fffb7565aa79bd6ae6f510ecc7ac29ed7cd0a98a7b948c10162c5c25c0
- 8eebef1167ba58681276502fdb907ce5f63d5bbbf68b887b2cc1b2dd4bbc177

- 4c5bbf836913bccd7d8a18ea3ac742057b14fc739b05502e74d389e36fa829bb